👣 Fase 1: Footprinting: DNS Brute Force

📖 Introducción a la Fase

El **Footprinting** es la etapa de recolección de información donde se busca mapear la superficie de ataque del objetivo. En este escenario, ejecutamos un **Reconocimiento Vertical** integral sobre `*.mercadolibre.com`, combinando técnicas pasivas e informadas para obtener un listado exhaustivo de activos.

🔨 1- DNS Brute force: Descubrimiento Activo

Esta técnica consiste en realizar consultas masivas a los servidores de DNS utilizando diccionarios de palabras para identificar subdominios que no están indexados públicamente.

⚙️ Configuración del Entorno de Trabajo

Para maximizar la cobertura, se optó por un enfoque de **doble diccionario**, asegurando tanto la detección de servicios comunes como de infraestructura específica:

- **Diccionario Estándar:** Uso de `/usr/share/wordlists/dirb/common.txt` (4,613 términos) para un mapeo inicial rápido.
- **Diccionario de Alta Densidad (SecLists):** Implementación de `subdomains-top1million-110000.txt` para detectar micro-servicios y activos *cloud-native*.
- **resolvers.txt:** Lista de servidores DNS externos (Google/Cloudflare) para validar peticiones masivas sin bloqueos.

📋 Comandos Ejecutados (`shuffledns`)

```
shuffledns -mode bruteforce -d mercadolibre.com -w wordlist.txt -r
resolvers.txt -silent > subdominios_meli_brute.txt

shuffledns -mode bruteforce -d mercadolibre.com -w subdomains-top1million-
110000.txt -r resolvers.txt -silent > subdominios_meli_PRO.txt
```

```
┌──(kali㉿kali)-[~]
└─$ go install -v github.com/projectdiscovery/nuclei/v3/cmd/nuclei@latest
go: downloading github.com/projectdiscovery/nuclei/v3 v3.7.1
go: downloading github.com/projectdiscovery/nuclei v1.1.7
go: downloading github.com/projectdiscovery/gologger v1.1.68
```

🧠 Análisis y Consolidación de Resultados

Tras procesar ambas ejecuciones y realizar una de duplicación técnica, se consolidó un total de **51 activos únicos** resueltos. El filtrado automático de registros **wildcard** garantizó la validez de los siguientes hallazgos críticos:

```
┌──(kali㉿kali)-[~]
└─$ nuclei -u mercadolibre.com -silent
[azure-domain-tenant] [http] [info] https://login.microsoftonline.com:443/mercadolibre.com/v2.0/.well-known/openid-configurati
on ["882c0c7c-23db-40e6-9992-5b2c0f064e05"]
[waf-detect:cloudfront] [http] [info] https://mercadolibre.com
[tls-version] [ssl] [info] mercadolibre.com:443 ["tls12"]
[tls-version] [ssl] [info] mercadolibre.com:443 ["tls13"]
[missing-sri] [http] [info] https://mercadolibre.com/ ["https://http2.mlstatic.com/ui/navigation/2.3.5/mercadolibre/navigation
.css"]
[http-missing-security-headers:strict-transport-security] [http] [info] https://mercadolibre.com
[http-missing-security-headers:permissions-policy] [http] [info] https://mercadolibre.com
[http-missing-security-headers:x-frame-options] [http] [info] https://mercadolibre.com
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] https://mercadolibre.com
[http-missing-security-headers:referrer-policy] [http] [info] https://mercadolibre.com
[http-missing-security-headers:clear-site-data] [http] [info] https://mercadolibre.com
[http-missing-security-headers:content-security-policy] [http] [info] https://mercadolibre.com
[http-missing-security-headers:x-content-type-options] [http] [info] https://mercadolibre.com
```

- **Identidad y Acceso:** `auth`, `idp`, `reg` (Puntos críticos de autenticación).
- **Desarrollo y Código:** `api`, `developers`, `artifacts` (Repositorios de artefactos y gestión de backend).
- **Infraestructura Interna:** `jira`, `wiki`, `hermes`, `hydra`, `snoopy` (Microservicios y gestión interna).
- **Operaciones Sensibles:** `facturacion`, `webhooks`, `envios` (Procesamiento de datos y eventos en tiempo real).
- **Entornos de Prueba:** `test`, `beta` (Superficies con controles de seguridad potencialmente reducidos).

⚖️ Nota sobre la Priorización

Aunque se han priorizado los activos mencionados por su impacto en la triada de seguridad (Confidencialidad, Integridad y Disponibilidad), la totalidad de los 51 subdominios permanecen bajo monitoreo para la Fase 3 de escaneo de servicios.